VULNSCAN SECURITY AUDIT REPORT

Automated Web Security Intelligence & Vulnerability Assessment

Target Host:	juice-shop.herokuapp.com	**Scan Date:**	2026-11-10 09:00:14
Target URL:	https://juice-shop.herokuapp.com	**Security Score:**	**33 / 100**
Scan Type:	FULL	**Status:**	COMPLETED
Total Findings:	5	**Critical / High:**	2 / 0

1. Executive Summary

This report documents security findings discovered during automated assessment of https://juice-shop.herokuapp.com. The evaluated target received an overall Security Posture Score of **33/100** (CRITICAL RISK). A total of **5** security findings were logged, comprising 2 Critical, 0 High, 2 Medium, 1 Low, and 0 Informational findings. All scanning operations were non-destructive and carried out strictly within authorized scope.

2. Vulnerability Findings & Technical Remediation

#1 Web Server Banner Disclosed (Heroku)	[LOW] (RECON)
Description:	The remote web server advertises its software identity: Heroku.
Evidence:	`HTTP Header Server: Heroku`
Remediation:	Configure the web server to suppress the 'Server' and 'X-Powered-By' headers.

#2 Missing Security Header: Strict-Transport-Security (HSTS)	[CRITICAL] (HEADERS)
Description:	Enforces secure HTTPS connections and protects against protocol downgrade attacks and cookie hijacking.
Evidence:	`Header 'strict-transport-security' is absent from HTTP response.`
Remediation:	Set 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload'

#3 Missing Security Header: Content-Security-Policy (CSP)	[CRITICAL] (HEADERS)

Description:	Mitigates Cross-Site Scripting (XSS) and unauthorized resource injection attacks.
Evidence:	`Header 'content-security-policy' is absent from HTTP response.`
Remediation:	Configure a strict CSP policy such as 'default-src \'self\'; script-src \'self\'; object-src \'none\';'

#4 Missing Security Header: Referrer-Policy	**[MEDIUM]** (HEADERS)
Description:	Protects user privacy and sensitive tokens in URLs from leaking to external referrers.
Evidence:	`Header 'referrer-policy' is absent from HTTP response.`
Remediation:	Set 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer'

#5 Missing Security Header: Permissions-Policy	**[MEDIUM]** (HEADERS)
Description:	Explicitly restricts browser features and APIs (webcam, microphone, geolocation) in web contexts.
Evidence:	`Header 'permissions-policy' is absent from HTTP response.`
Remediation:	Set 'Permissions-Policy: camera=(), microphone=(), geolocation=()'